The Myth(os) of Keeping Up: Breaking the Patch Barrier Through Machine-Speed Virtual Patching

Victor Weis, Consulting Solutions Architect
Franklin County Cyber Summit
2026-10-07

About Me

Who is Victor Weis

- Consulting Solutions Architect with Fortinet for 5 years
- 20 years as an implementation practitioner prior to that
- Based in Dayton, OH – born & raised!
- Spoken at OHECC, OISC, (KY)NUG, WVSTC, ACS, etc.
  - Github: https://github.com/weis-victor/presentations
  - Linkedin: https://www.linkedin.com/in/victor-weis/



© Fortinet Inc. All Rights Reserved.

Abstract

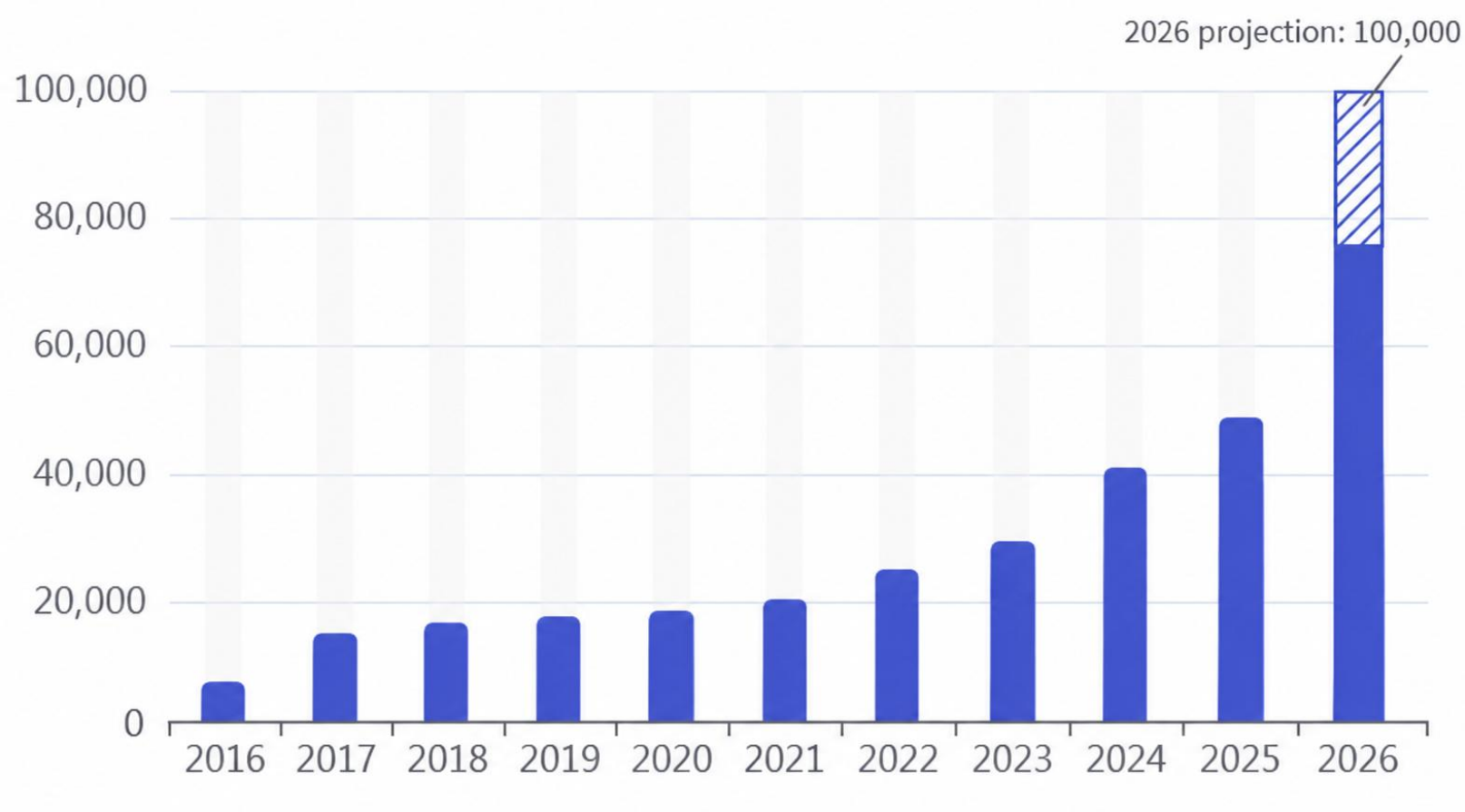
What This Talk Will Be About

- According to the 2026 Verizon DBIR, “Exploitation of a Vulnerability” has become the most common Initial Access Vector in cyber breaches, far surpassing all other vectors like Phishing or Credential Abuse.
- The key driving factor for this trend is the advent of Mythos-level models accelerating vulnerability discovery, weaponization, and delivery way faster than organizations can patch.
- This talk will examine the evidence for “The Patch Barrier” and offer practical strategies to overcome it in this new landscape.
- In particular, virtual patching strategies will be recommended as the #1 priority to focus on in the near-to-medium term

© Fortinet Inc. All Rights Reserved.

CVE You Later: The Vulnerability Landscape

Exponential CVE Growth in Recent Years (Graphic Updated Oct 2026)



- New AI tooling rapidly accelerates the rate of vulnerability discovery
- 2026 likely to have ~100K CVEs published
- Doubles the 2025 total of 49K
- New developments like Mythos will only accelerate this further

Source: https://www.cvedetails.com/browse-by-date.php

© Fortinet Inc. All Rights Reserved.

Context: The Attack Pattern Landscape

Verizon DBIR 2026: System Intrusion patterns now accounts for >61% of all breach patterns

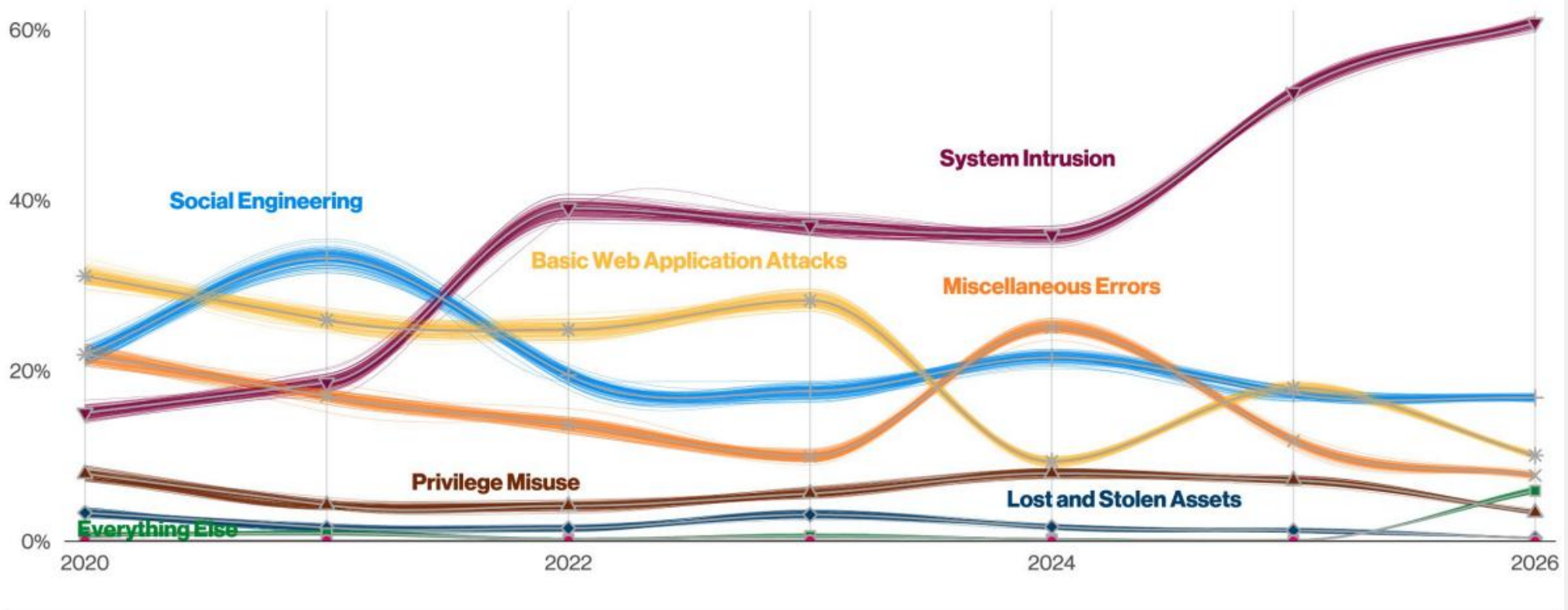


Figure 40. Patterns over time in breaches (n for 2026 dataset=22,624)

Source: https://www.verizon.com/business/resources/reports/dbir/ (p38)

- More vulns means more breaches via System Intrusions over time
  - This is true in both relative and absolute terms

© Fortinet Inc. All Rights Reserved.

Caught with your Patches Down: More Vulns = More Exploits

Top Key Finding of Verizon DBIR 2026: Exploitation of Vulnerabilities is the MOST common Initial Access vector at 31%

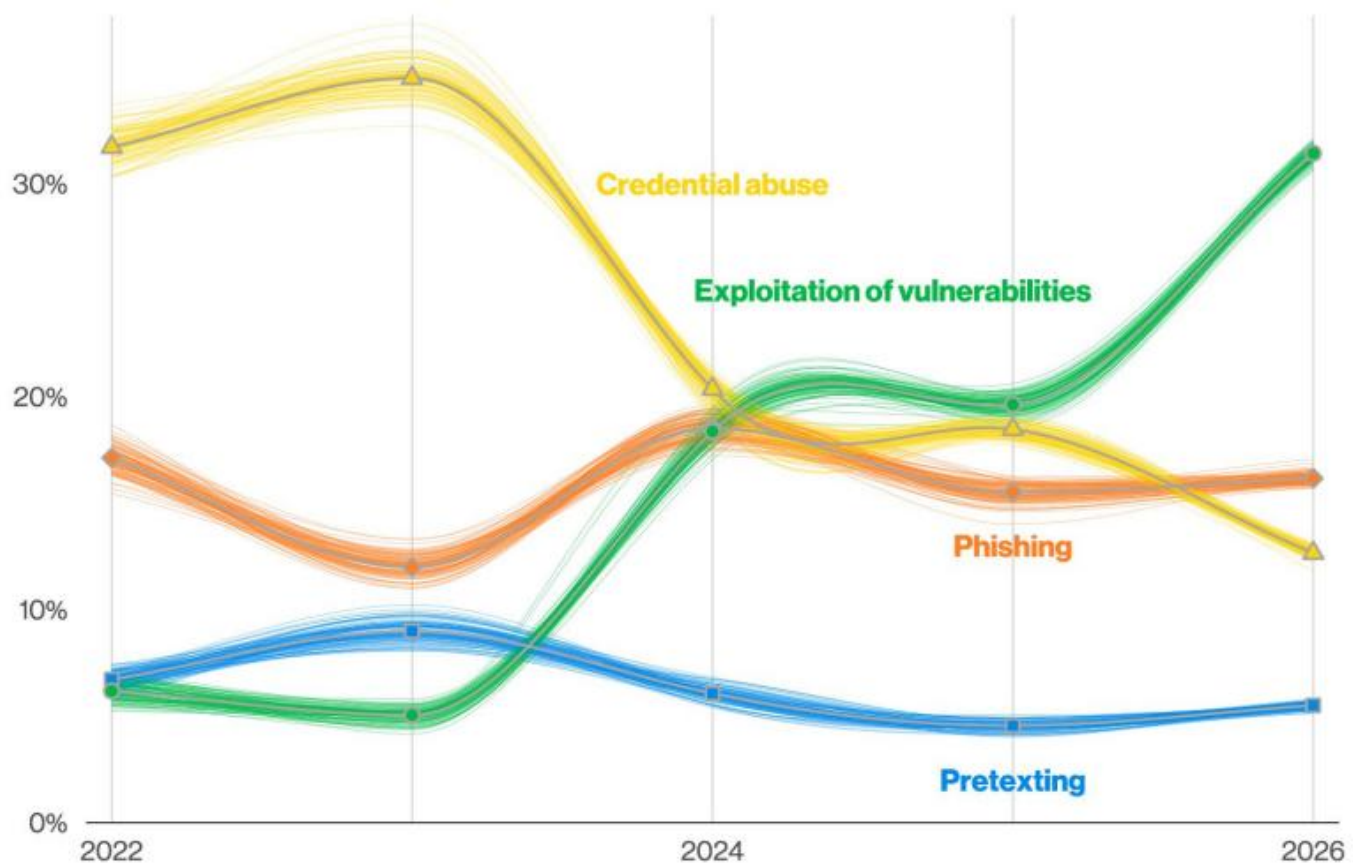
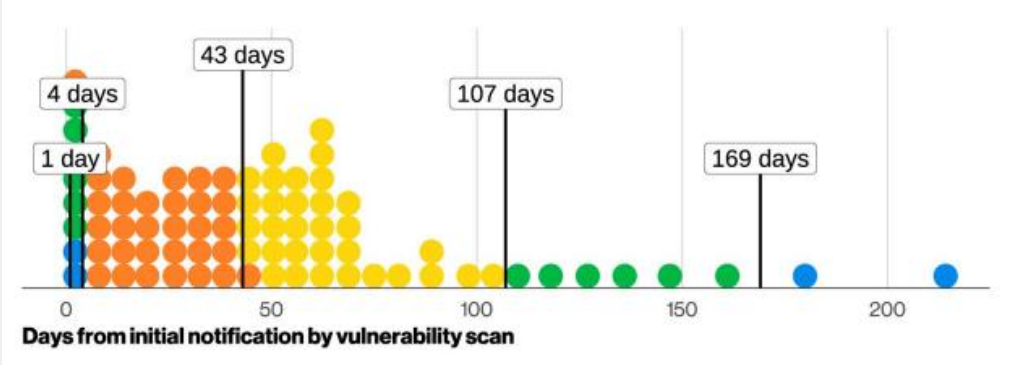


Figure 5. Known initial access vectors in non-Error, non-Misuse breaches over time (n for 2026 dataset=19,905)

- "Only 26% of [KEVs] were fully remediated by orgs in 2025, a drop from the previous year's 38%."
- "Median time for full resolution increased from 32 to 43 days."
- "On average, orgs had 50% more critical vulns to patch than last year."
- "There are too many vulns and not enough time for patching all of them."



Source: https://www.verizon.com/business/resources/reports/dbir/ (p10)

© Fortinet Inc. All Rights Reserved.

AI Ate Your Patch Window: Patching Programs Cannot Keep Up

Top Key Finding of Verizon DBIR 2026: Hard Speed Limits for Traditional Patching

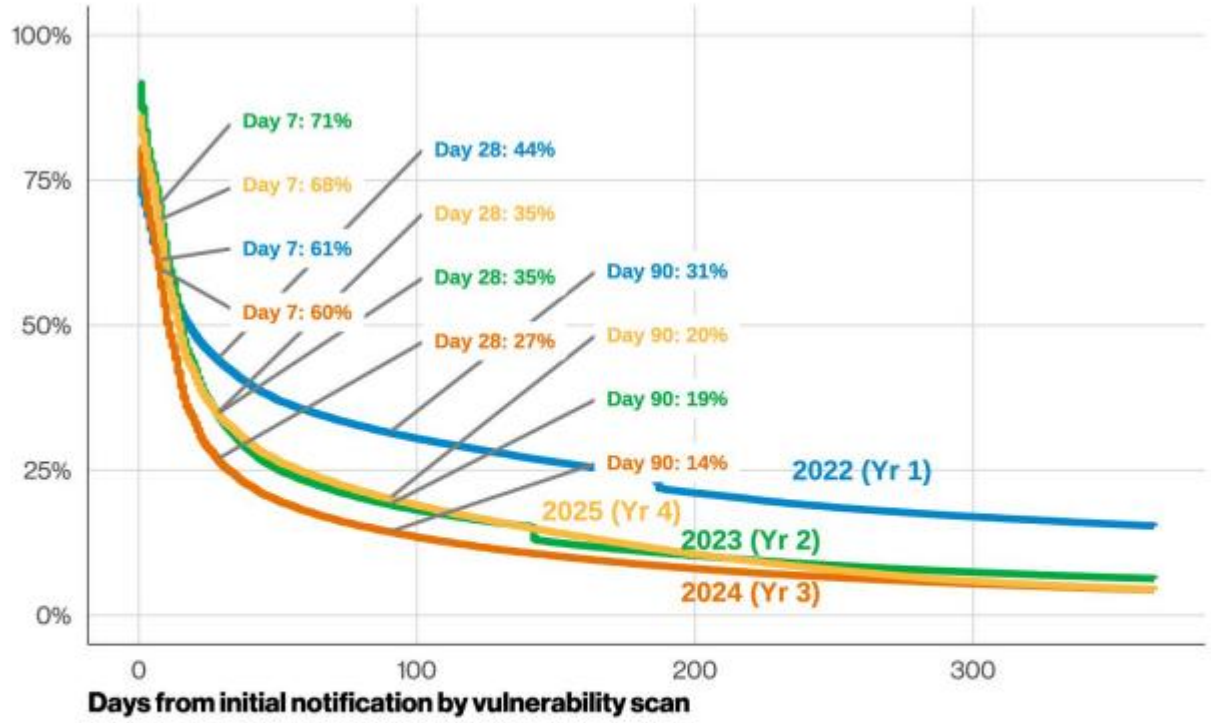


Figure 15. CISA KEV vulnerability survival analysis: four-year comparison (2022–2025) (n for 2022=68,697,749 vulnerability instances) (n for 2023=120,803,360 vulnerability instances) (n for 2024=295,795,092 vulnerability instances) (n for 2025=527,255,454 vulnerability instances)

- "There appears to be a ceiling, and the data suggests diminishing returns at current resource levels."
- "By Day 7…between 60-70% of KEVs remain open – regardless of year, volume or organizational maturity."
- "This might be a… '**speed of light**' for vulnerability remediation processes."
- "Organizations at their very best only get to fix 30%–40% of KEV instances in the first week after detection."

Source: https://www.verizon.com/business/resources/reports/dbir/ (p18)

© Fortinet Inc. All Rights Reserved.

What is to be done!?

Making the Least Pessimal Choice

- Better prioritization of traditional patching?
  - This is hopeless – IMO
- Re-write everything in Rust?
  - Rust is inherently “memory-safe”
  - Would fix about ~70% of high/critical vulns
    - E.g. buffer overflows, use-after-free, heap corruption, etc.
    - Estimates from Google, Microsoft, Linux Foundation
  - Doesn’t fix logic bugs, injections, supply chain attacks, weak crypto, config errors
  - A ~70% vuln reduction would get us back to 2024 levels, when we could still breathe
  - Will take a long time to re-write EVERYTHING in Rust
  - But at least get started! Ask your vendors and developers!
  - AI should help accelerate this (e.g. Ubuntu Core Utils)
- Other memory protection techniques?
  - (K)ASLR, PIE, RELRO, Stack Canaries, Various Heap Protections, etc.
  - None of these solve data-only memory attacks



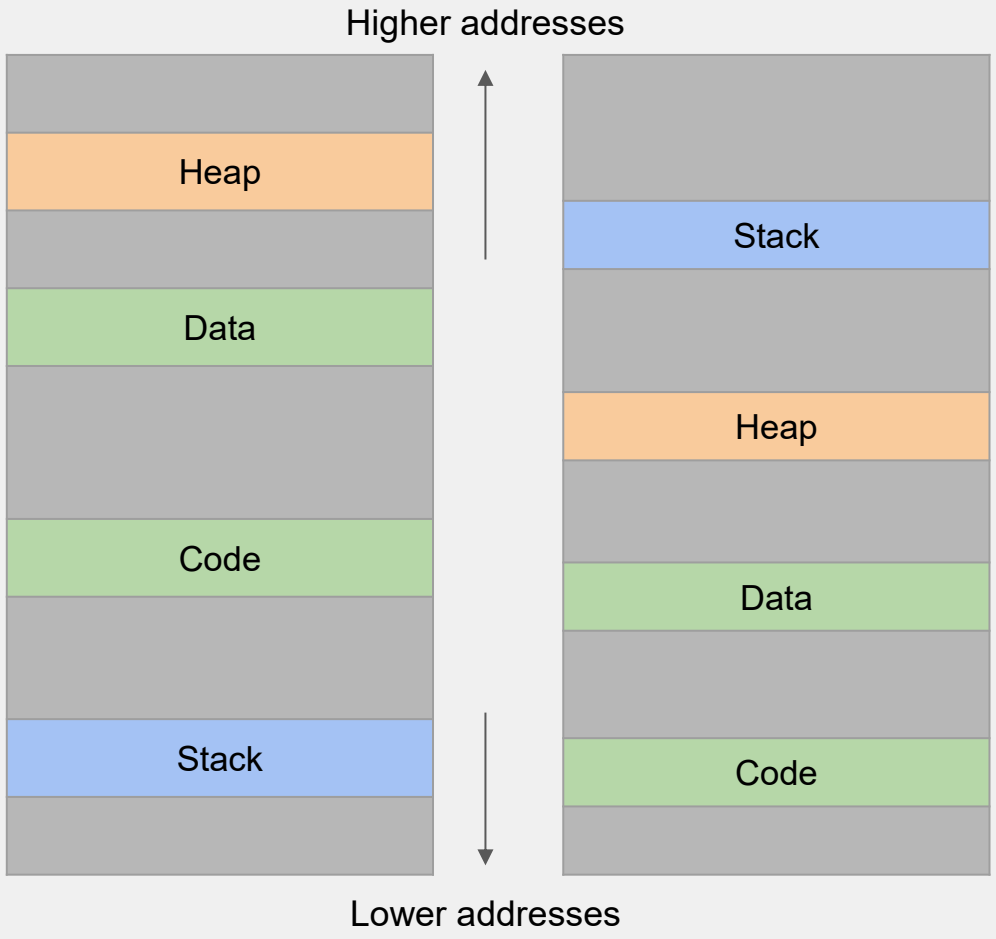
© Fortinet Inc. All Rights Reserved.

Mitigating Memory-Based Attacks: (K)ASLR, PIE, & RELRO

Proactive Defense-in-Depth

- Hardens runtime memory layout with a layered set of build-time and load-time protections:
  - (Kernal) Address Space Layout Randomization
  - Position Independent Executable
  - Read-Only Relocations
- Together, these techniques greatly raise the difficulty of exploiting memory corruption vulnerabilities such as buffer overflows

Mechanism	Scope	Protects	Effect
ASLR	Userspace (per process)	Stack, heap, shared libraries	Randomizes memory locations at runtime
PIE	Userspace (main executable)	Main executable	Extends ASLR coverage to the binary's own code
RELRO	Userspace (process)	GOT (function call table)	Prevents runtime tampering with resolved functions
KASLR	Kernel	Kernel base address and module load addresses	Randomizes the kernel's location at boot



Put each segment of memory in a randomized location each runtime

Source: https://docs.fortinet.com/document/fortigate/8.0.0/administration-guide/972404/fortios-memory-protection-aslr-kaslr-pie-and-relro-new

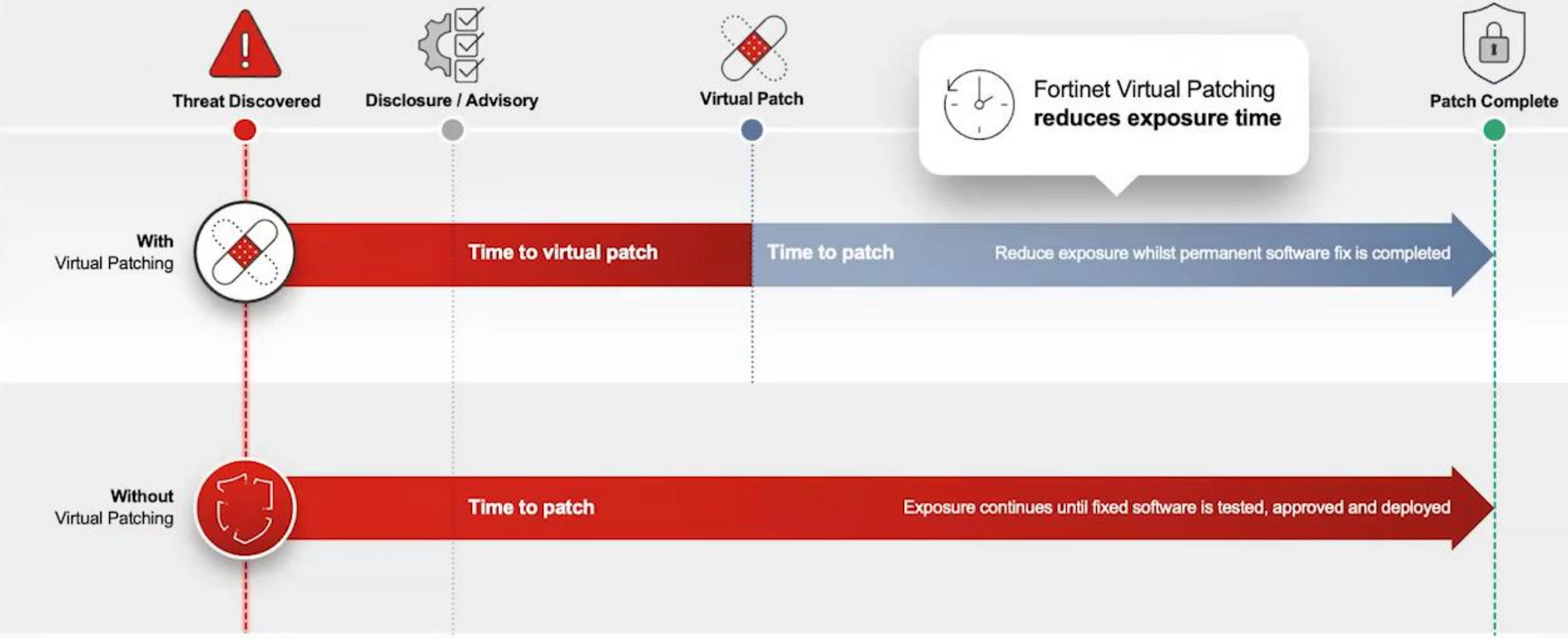
What is to be done!?

Traditional Patching vs Virtual Patching

- Traditional Patching consists of updating the code, and installing the update to prod
  - This takes a LONG time – often TOO long to prevent breaches – as we saw in the DBIR 2026 data
- OWASP Defines Virtual Patching as:
  - "**A security policy enforcement layer which prevents the exploitation of a known vulnerability**.
- Virtual Patching is way faster because it can be deployed inline, without downtime
  - Examples of Virtual Patching systems include
    - NGFW/IPS
    - WAF
    - SSE/SASE
    - Anti-Exploit features of EPPs
- Virtual Patching does NOT replace Traditional Patching
  - It buys you time

© Fortinet Inc. All Rights Reserved.

Virtual Patching closes the exposure gap

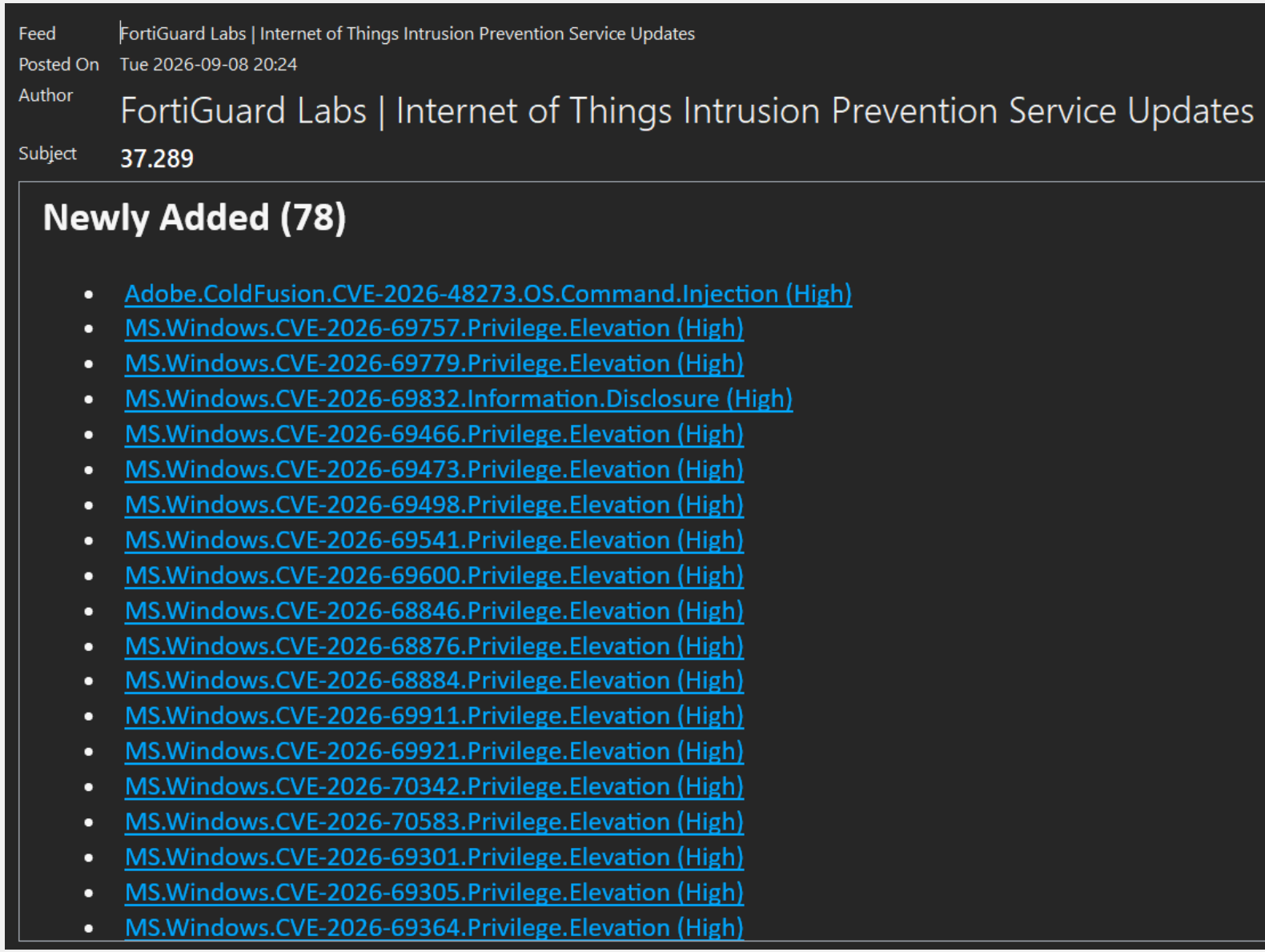


© Fortinet Inc. All Rights Reserved.

Patch Tuesday, September 2026

Microsoft Breaks the Record with 974 CVEs patched, including 110 critical

- IPS Signatures provided same-day instant protection as a virtual patch for 78 out of the 110 critical flaws
- Dozens more signatures were provided in subsequent days for the lower severity flaws



Feed FortiGuard Labs | Internet of Things Intrusion Prevention Service Updates
Posted On Tue 2026-09-08 20:24
Author FortiGuard Labs | Internet of Things Intrusion Prevention Service Updates
Subject 37.289

Newly Added (78)

- Adobe.ColdFusion.CVE-2026-48273.OS.Command.Injection (High)
- MS.Windows.CVE-2026-69757.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69779.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69832.Information.Disclosure (High)
- MS.Windows.CVE-2026-69466.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69473.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69498.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69541.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69600.Privilege.Elevation (High)
- MS.Windows.CVE-2026-68846.Privilege.Elevation (High)
- MS.Windows.CVE-2026-68876.Privilege.Elevation (High)
- MS.Windows.CVE-2026-68884.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69911.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69921.Privilege.Elevation (High)
- MS.Windows.CVE-2026-70342.Privilege.Elevation (High)
- MS.Windows.CVE-2026-70583.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69301.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69305.Privilege.Elevation (High)
- MS.Windows.CVE-2026-69364.Privilege.Elevation (High)

But I Have Virtual Patching Systems Already!?

Implementation Details Are Key

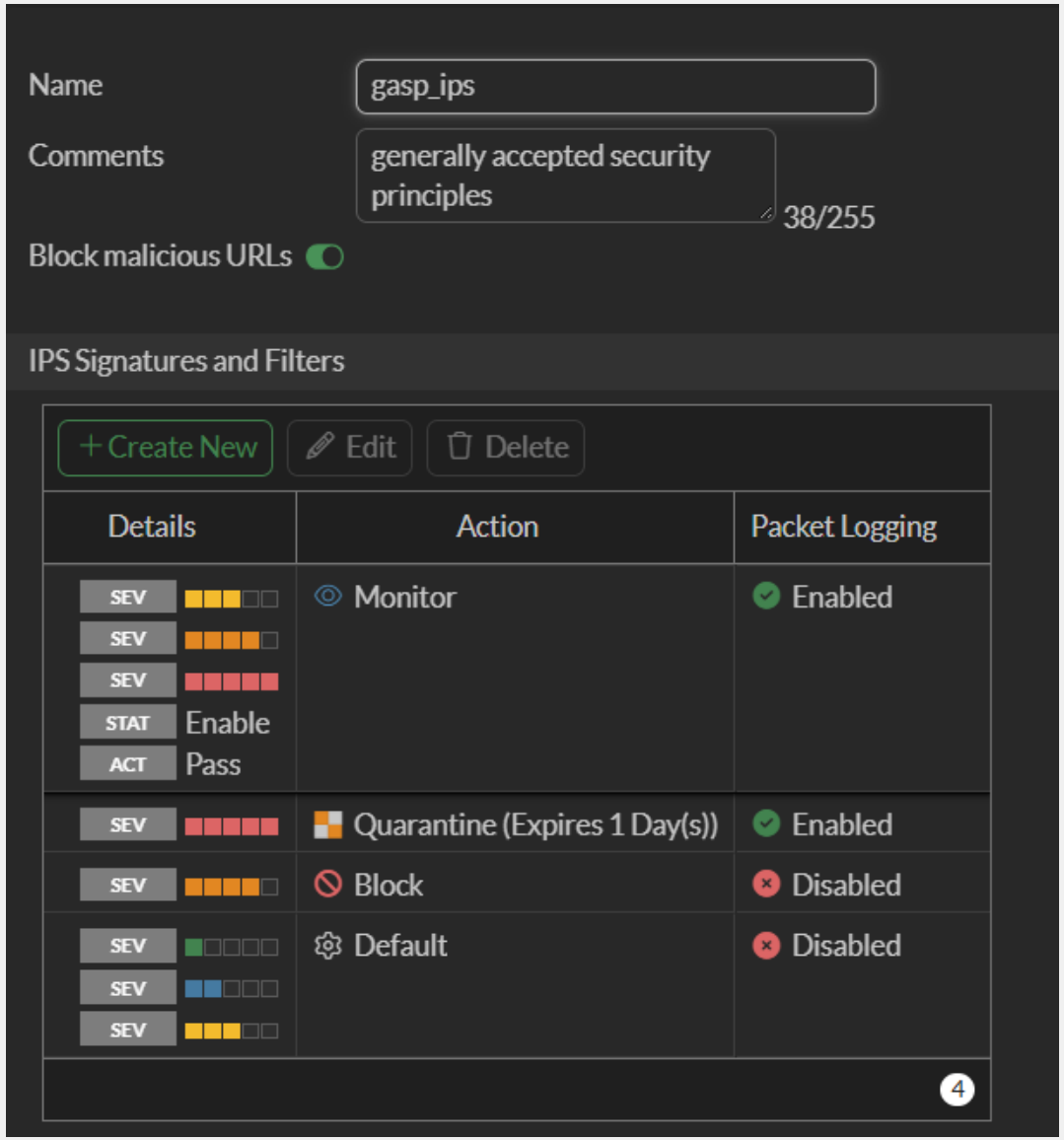
- Most organizations have some level of virtual patching systems deployed today
- Actual effectiveness is often limited by implementation deficiencies
  - Edge-only Deployment vs Segmentation vs Micro-Segmentation
  - Lack of Deep SSL Inspection
    - See my talk “Deep SSL for the Real World”
  - Lack of QUIC/HTTP3 Inspection
    - See my talk “The QUICening”
  - Lack of SNI Spoofing Prevention in TLS 1.3
    - Upcoming talk on “SNIpper ATT&CKs!” (2027 TBD)
  - Inadequate SIEM monitoring
  - Default Settings

© Fortinet Inc. All Rights Reserved.

Differentiated Actions

Generally Accepted Security Principles (GASP) IPS

- Signatures are initially released in a with an “Pass” action to give time for confidence building through telemetry collection.
- This helps to reduce false-positives but can also leave blind spots if not monitored
- Generally good to change action to Monitor + Packet Logging for these and monitor in your SIEM
- Considering using Quarantine for Critical severity attacks for mature signatures, combined with Packet Logging for deeper IR
  - Focus your SOC on signal
  - Limit the noise
- High severity usually doesn’t need Packet Logging
- Medium and below: take Default action



Easy Micro-Segmentation

Combine Private VLAN with Proxy ARP on a Firewall

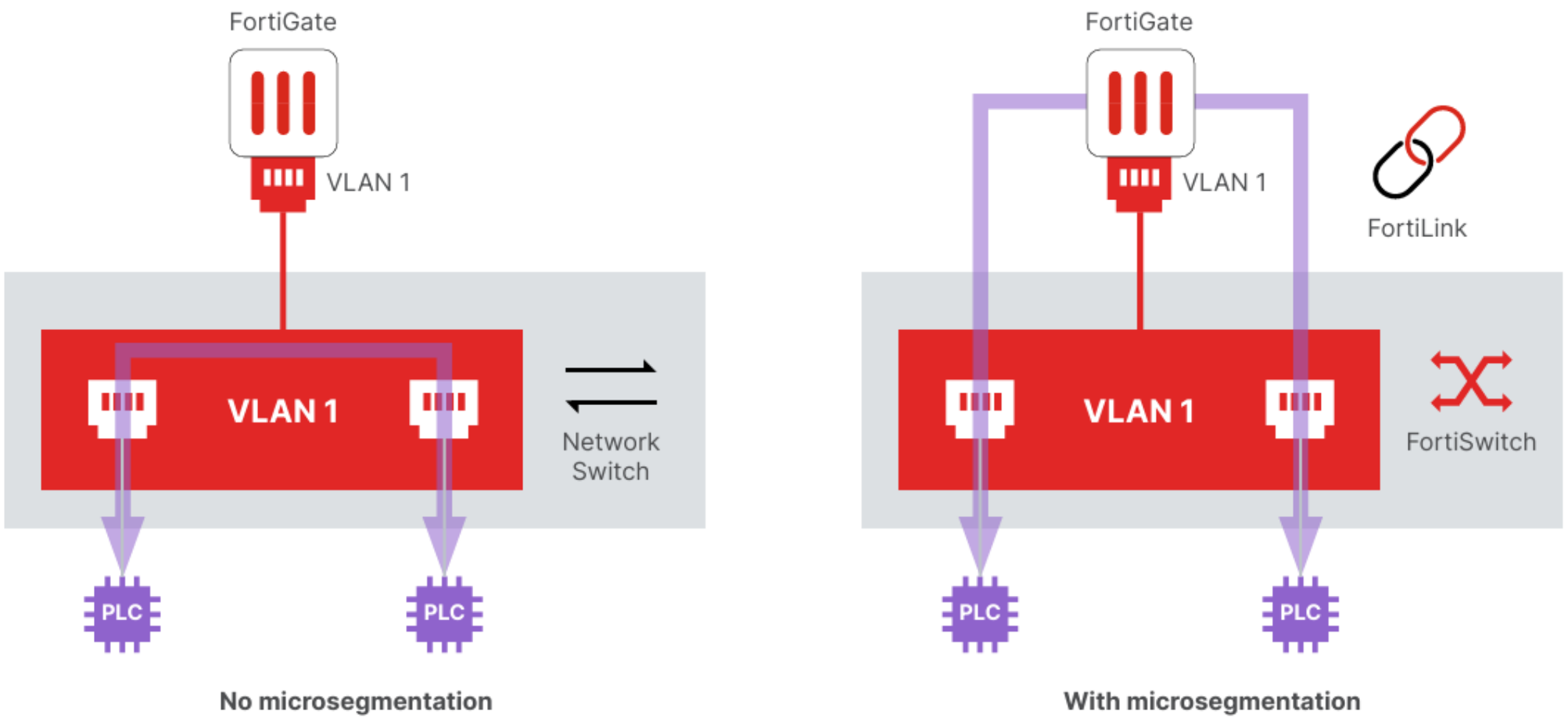
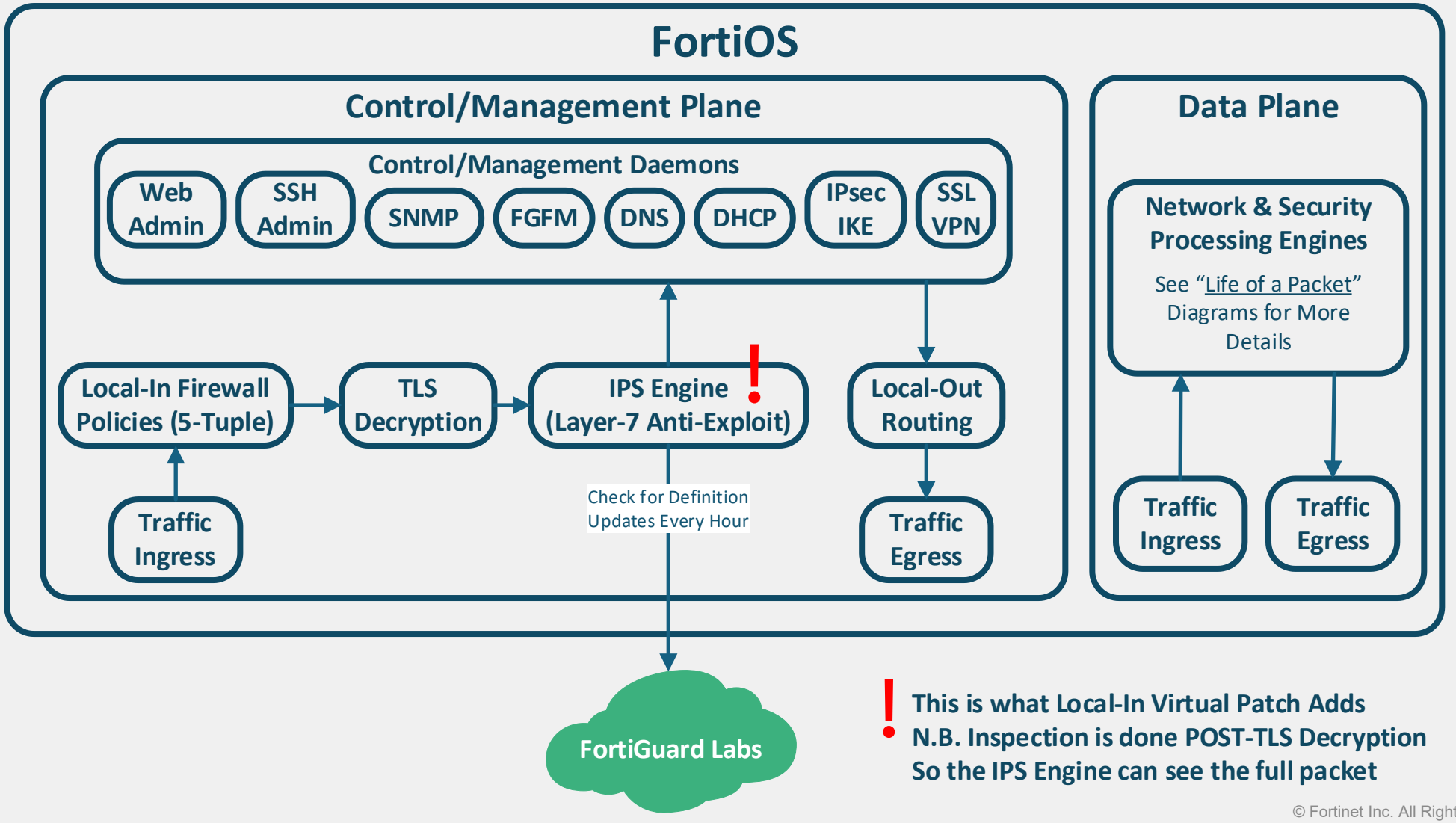


Figure 3: Normal VLAN routing vs. network microsegmentation using Fortinet FortiSwitch and FortiGate

© Fortinet Inc. All Rights Reserved.

Who Patches the Patcher?

Virtual Patching Systems Must Also Virtually Patch Themselves



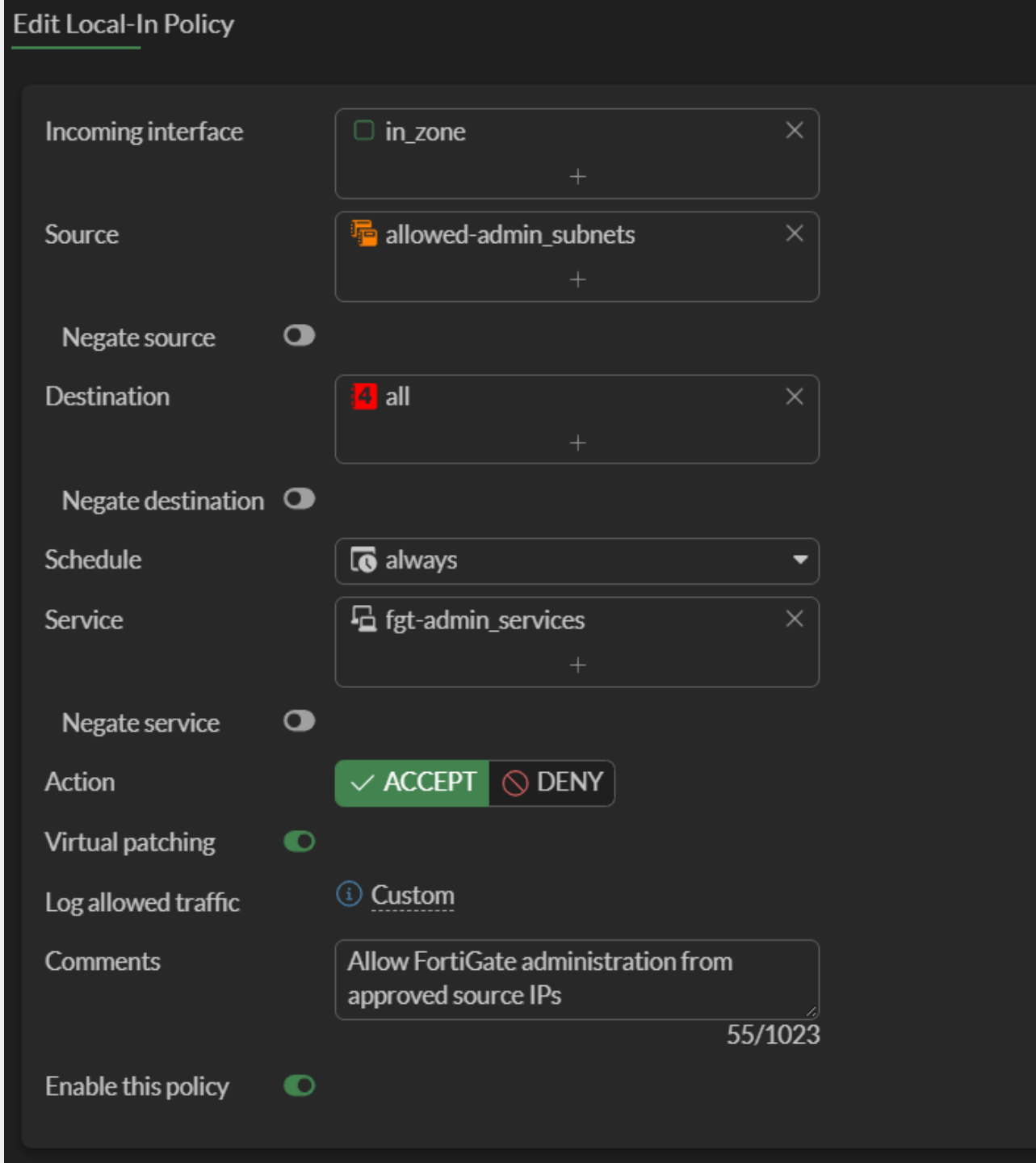
! This is what Local-In Virtual Patch Adds
N.B. Inspection is done POST-TLS Decryption
So the IPS Engine can see the full packet

© Fortinet Inc. All Rights Reserved.

Single Radio Button

Just Enable It





Questions?

And Slide Link

- Thank you for attending my talk!
- Slides:
  - https://github.com/weis-victor/presentations

© Fortinet Inc. All Rights Reserved.